



Hewlett Packard
Enterprise

FY-26: CAREER PREVIEW PROGRAM PROJECT REVIEW (CPP-3)



Updated June 2026
College/University Name: **JECRC**

Zero Touch Vulnerability Remediation System

PROJECT OVERVIEW

Project Name

Zero Touch Vulnerability
Remediation

College / University

JECRC

Project Repository

<https://github.com/Rahul-Data-Scientist/Zero-Touch-Vulnerability-Remediation>

PROJECT TEAM

1. Sidharth Banthia
2. Rahul Raj
3. Vaibhav Samdani
4. Abhimanyu Joshi
5. Prince Jain

MENTORS

HPE MENTORS

Thavamani Raja S.
Vivek Chinta

COLLEGE MENTOR

Dr. Seema Sharma



Problem Statement

The current vulnerability remediation lifecycle is entirely dependent on manual execution at every stage.

Slow Triaging

Existing processes are manual, repetitive, and drain critical engineering resources.

Remediation Overhead

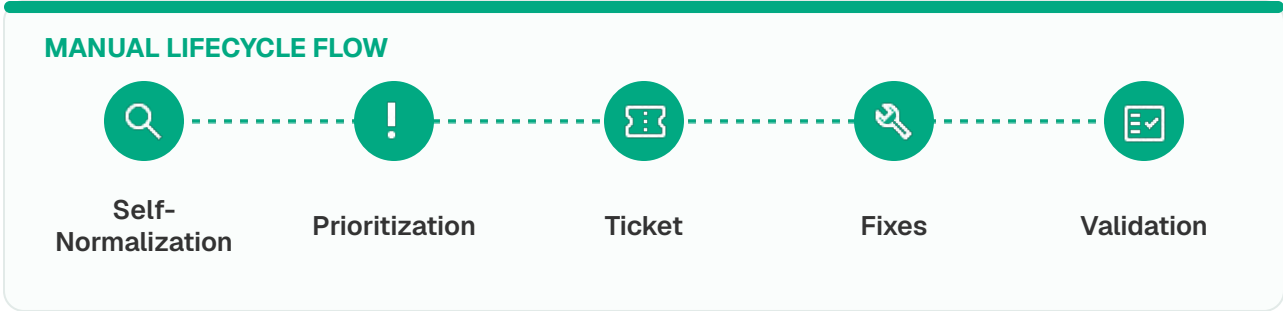
Manual workflows extend timelines and dramatically increase operational overhead.

Inefficient Prioritization

Unable to identify critical vulnerabilities due to lack of risk and business context.

Human-Dependency Risks

High dependency on manual execution leads to delays, inconsistencies, and missed gaps.



BUSINESS IMPACT

Mean Time to Remediate (MTTR)

Prolonged window of exposure to active exploits

Operational Cost

High manual labor overhead and repetitive tasks

Security Risk

Increased likelihood of human error and oversights

Analyst Productivity

Teams are bogged down with alert fatigue and sorting

HPE Confidential

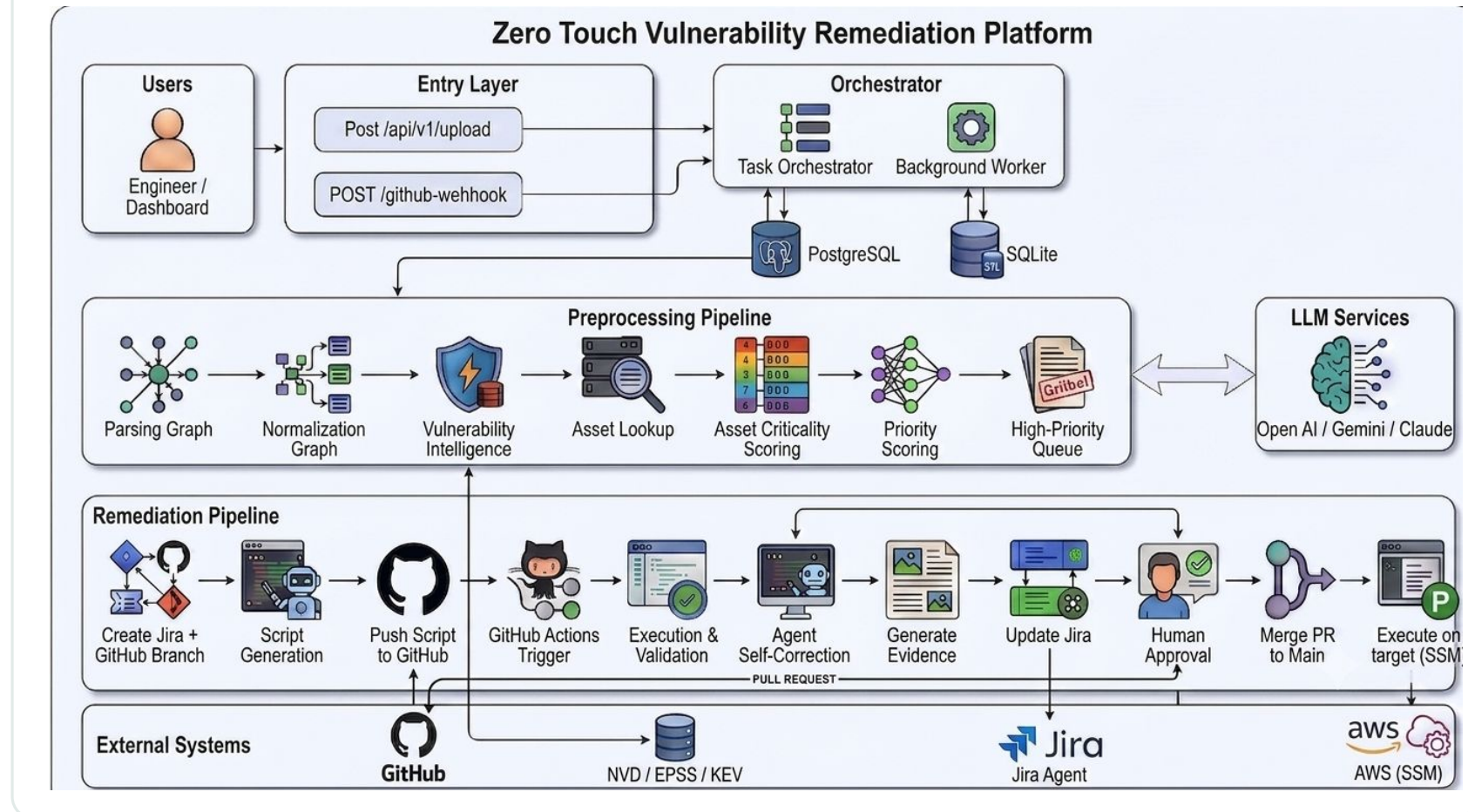
3

Proposed Solution

Autonomous, end-to-end pipeline from multi-scanner aggregation to automated deployment.

- **Multi-Scanner Aggregation**
Consolidates findings from multiple security scanners into one view
- **Business Content Dependency**
Measures business importance and asset's dependency
- **Intelligent Prioritization**
Ranks vulnerabilities using risk and business context
- **LLM Remediation Generation**
Produces vulnerability-specific remediation scripts automatically
- **Self-Correction Loop**
Learns from failures and retries with improved actions
- **Human Approval Gates**
Maintains oversight before production deployment
- **Evidence Generation**
Captures before-and-after proof for full auditability
- **Automated Deployment**
Applies approved fixes to live target systems seamlessly

OVERALL WORKFLOW



Parser Agent

Translating multi-scanner outputs into unified, structured single dataset for autonomous AI remediation.

Automated Report Parsing

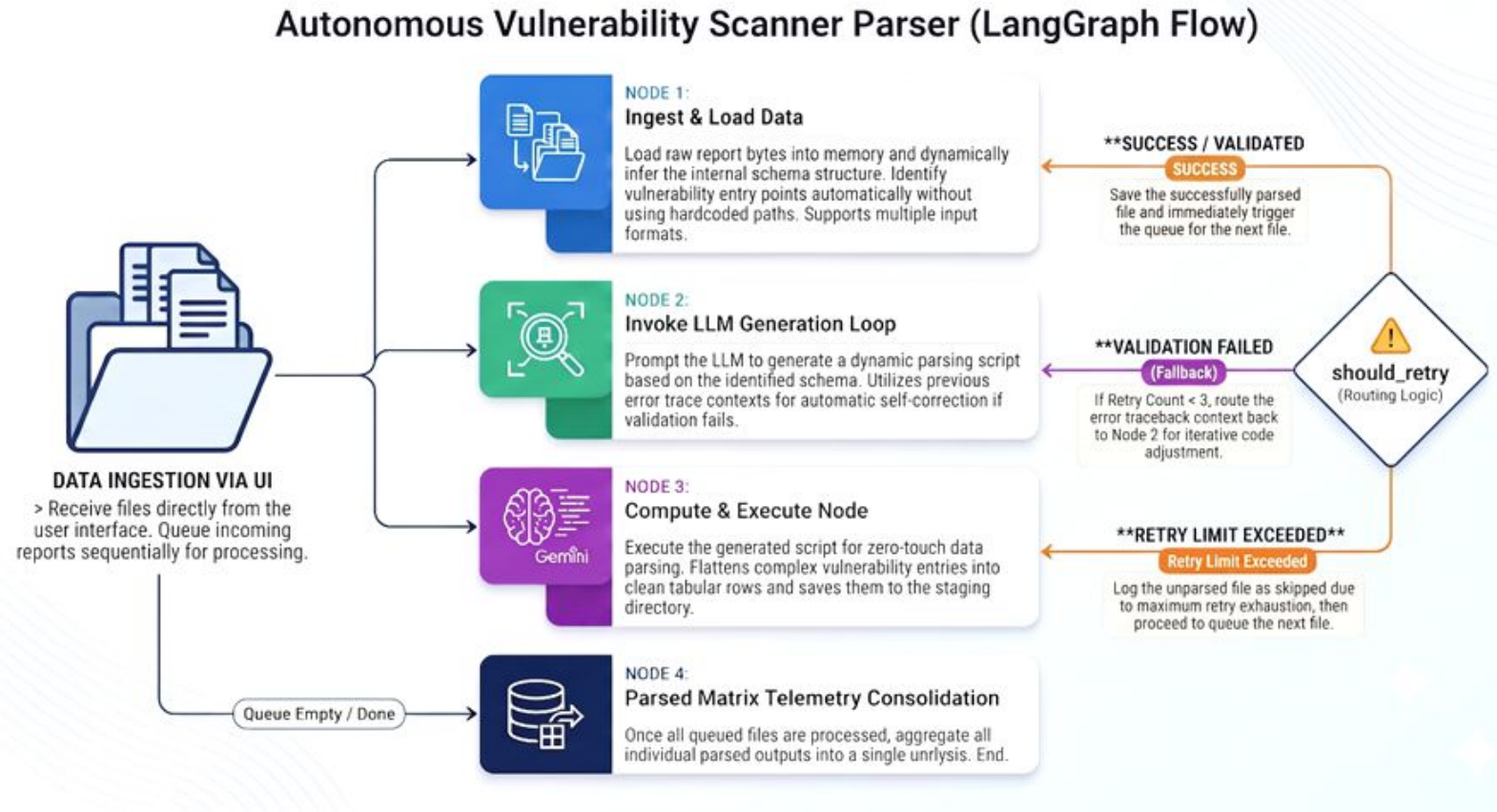
User ingests vulnerability reports from multiple security scanners and extracts structured security data.

AI-Driven Parser Generation

Generates, executes, and validates parser logic dynamically based on the target schema without requiring scanner-specific parsers.

Self-Correcting Execution

Automatically detects parsing errors, regenerates improved parser logic, and retries until successful validation or the retry limit is reached.



Normalization Agent

Translating multi-scanner outputs into unified, structured single dataset for autonomous AI remediation.

Automated Processing

Removes inconsistencies and reduces manual data processing efforts.

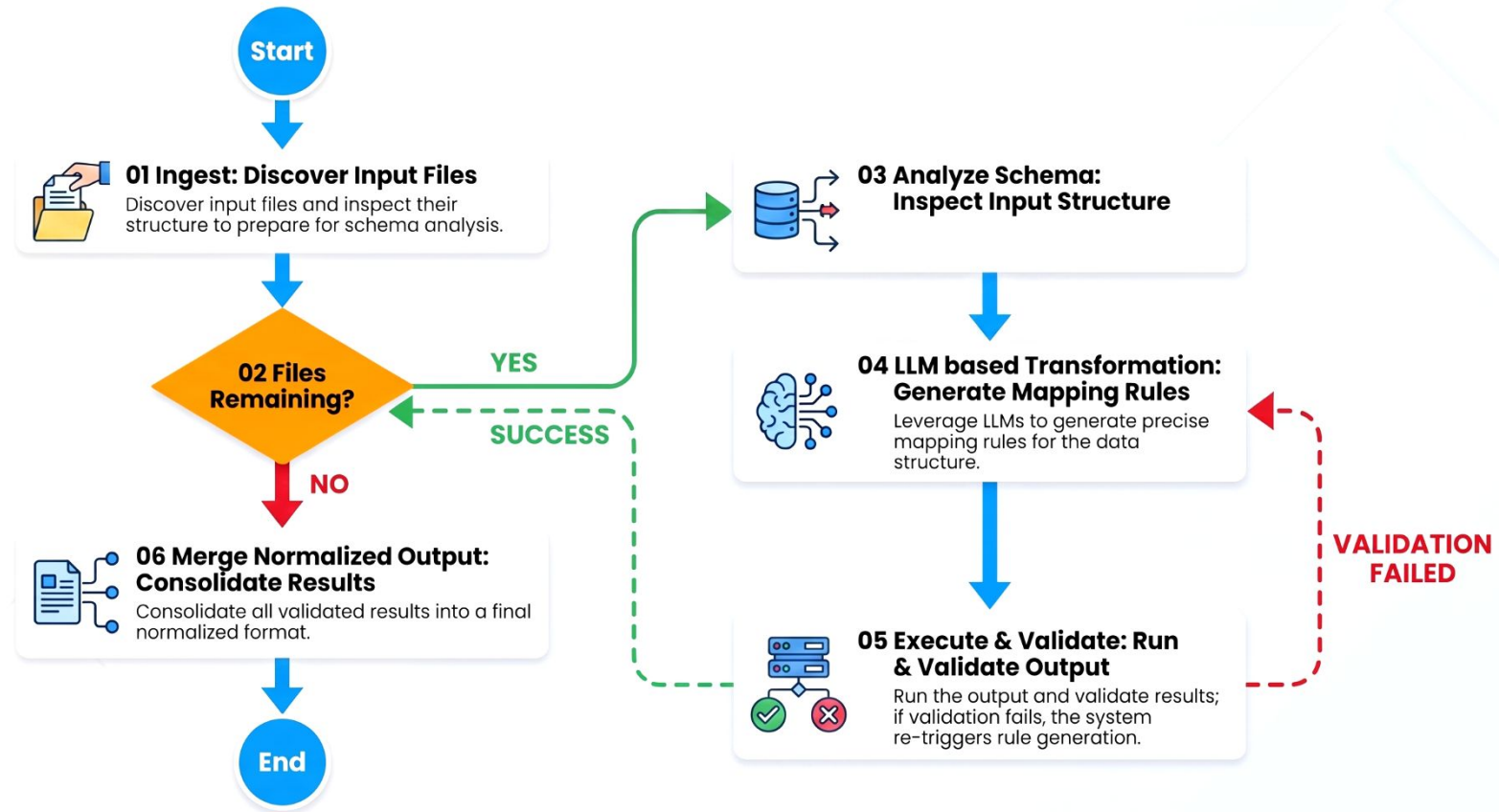
Dynamic Schema Mapping

Automatically maps diverse scanner formats into a unified enterprise schema using LLM-generated normalization logic.

Data Standardization

Provides clean, structured data for risk analysis, AI processing, and automated vulnerability remediation.

Automated LLM-Driven Data Normalization Workflow



Prioritization Engine

Automated risk processing and multi-factor scoring for rapid downstream remediation.

1. Intelligent Caching

Queries PostgreSQL for existing asset-vulnerability scores, instantly reusing historical data to eliminate redundant processing.

2. Multi-Factor Risk Scoring

Calculates a 0-10 priority score weighting **CVSS (25%)**, **Asset Criticality (25%)**, **EPSS (20%)**, **KEV (20%)**, **Fix Availability (5%)**, and **Vulnerability Age (5%)**.

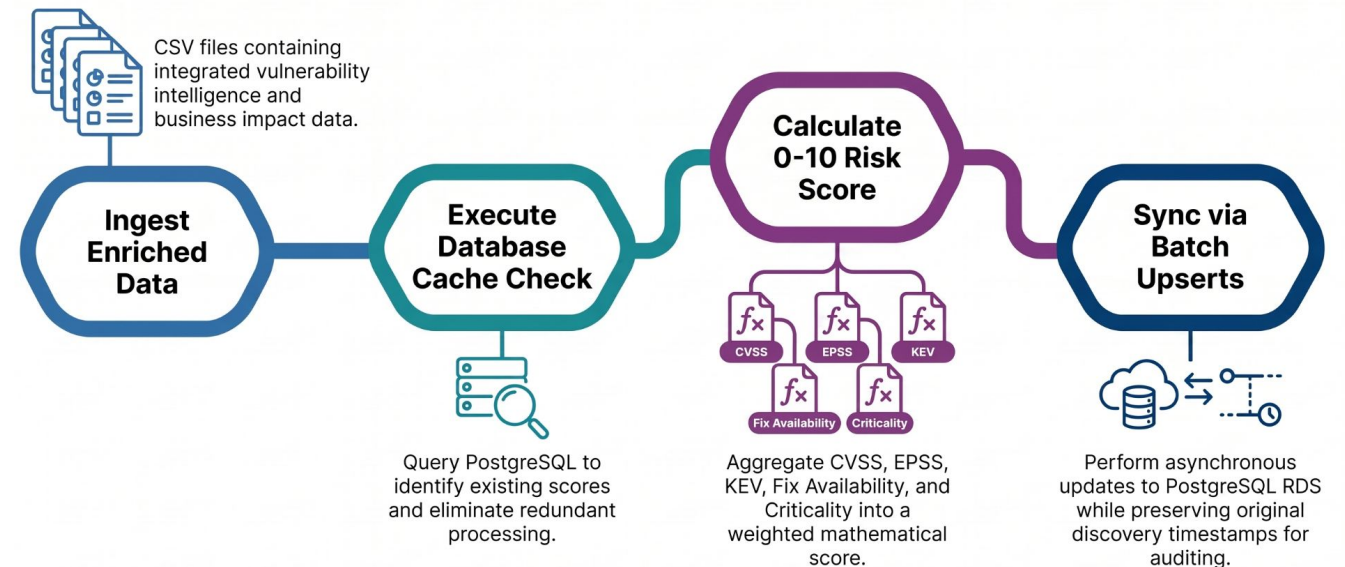
3. Data Persistence & Handoff

Saves calculated scores, risk levels (e.g., CRITICAL), and patch data back to the central CSV for seamless downstream remediation.

4. Asynchronous Batch Upserts

Uses a high-speed asyncpg pipeline to efficiently batch-insert new records and natively update existing PostgreSQL rows.

Automated Risk Prioritization Workflow



Asset Criticality Engine

WHY IT MATTERS

Business Impact Visibility

Shows how much operational or business damage a compromised asset can cause, not just how severe the vulnerability is.

Dependency & Blast Radius Awareness

Identifies assets that other systems rely on, helping estimate cascading impact if a critical asset goes down.

Asset Context Intelligence

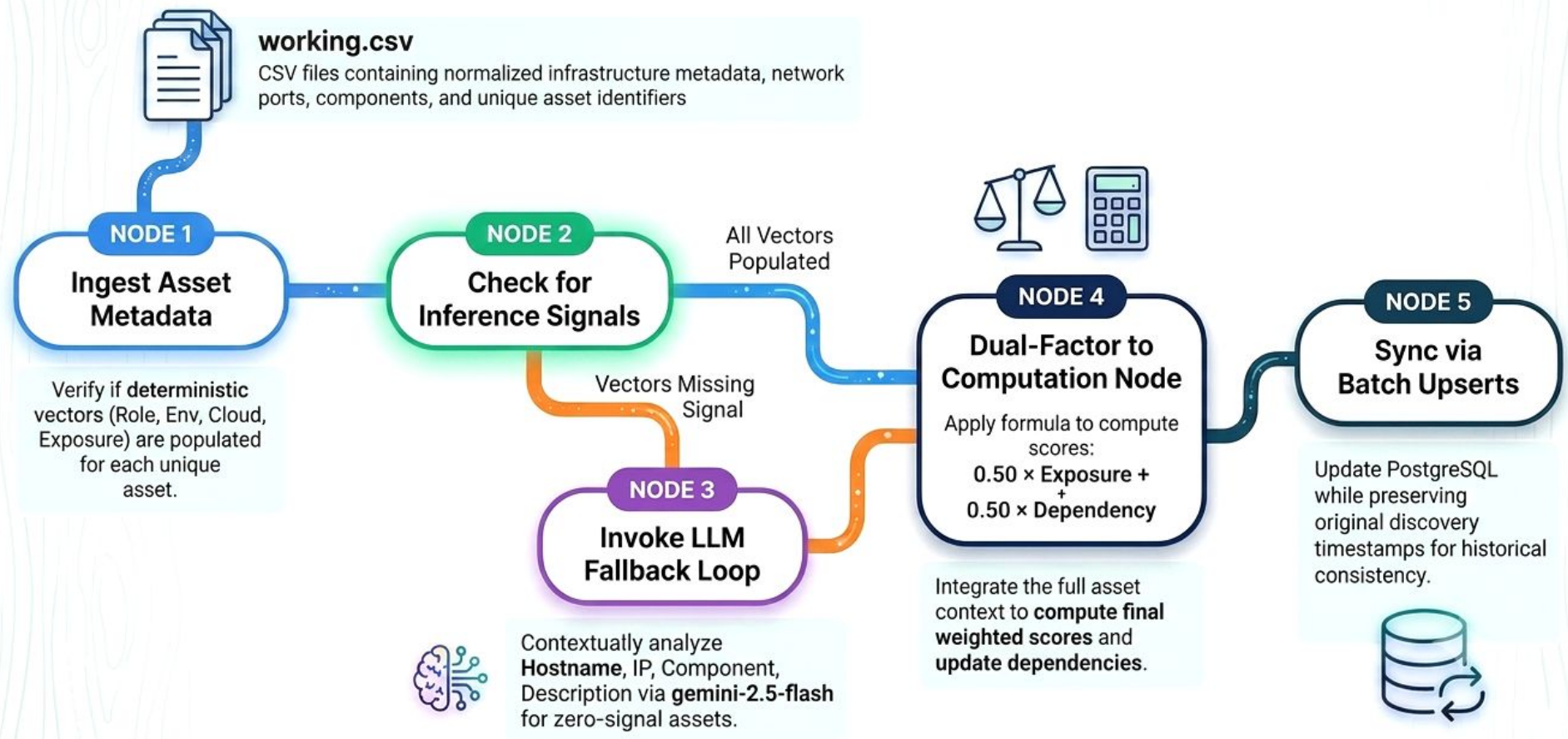
Adds infrastructure context like asset role, exposure, environment, and cloud relevance—turning raw scanner findings into meaningful risk insight using multi-vector inference.

SCORED EXAMPLES | Asset Criticality = (Exposure × 0.50) + (Dependency × 0.50)

Component (derivation context)	Raw	Weight	Score
Example A DataBase — Public IP · Production · AWS			
Exposure Score (Public IP → max exposure)	1.00	× 0.50	0.50
Dependency Score (Database + Prod + Cloud)	0.90	× 0.50	0.45
ASSET CRITICALITY SCORE = 0.50 + 0.45 = 0.95 → CRITICAL			
Internet-facing, payment role, AWS cloud presence — highest risk tier.			
Example B Database — Localhost · Non-Prod			
Exposure Score (Localhost → min exposure)	0.20	× 0.50	0.10
Dependency Score (Test role + Non-prod + No cloud)	0.20	× 0.50	0.10
ASSET CRITICALITY SCORE = 0.10 + 0.10 = 0.20 → LOW			
Localhost, dev/test role, on-prem, no sensitive data or compliance requirements — lowest risk tier.			
Same Asset but different context — Example A (0.95) is always prioritised over Example B (0.175). No manual triage needed.			

Asset Criticality Flow

Asset Criticality Evaluation Workflow



Automated Remediation Workflow

Automated Patch Lifecycle: Safe Staging, Human-Verified Integrity, and Integrated Jira Governance

1. Research & Remediation Generation

Create a JIRA ticket, gather remediation guidance from advisories, and use LLM to generate Precheck, Remediation, and Validation scripts.

2. Sandbox Validation

Execute scripts on a sandboxed (cloned) VM through the CI/CD pipeline to safely validate the generated patch.

3. Self-Healing

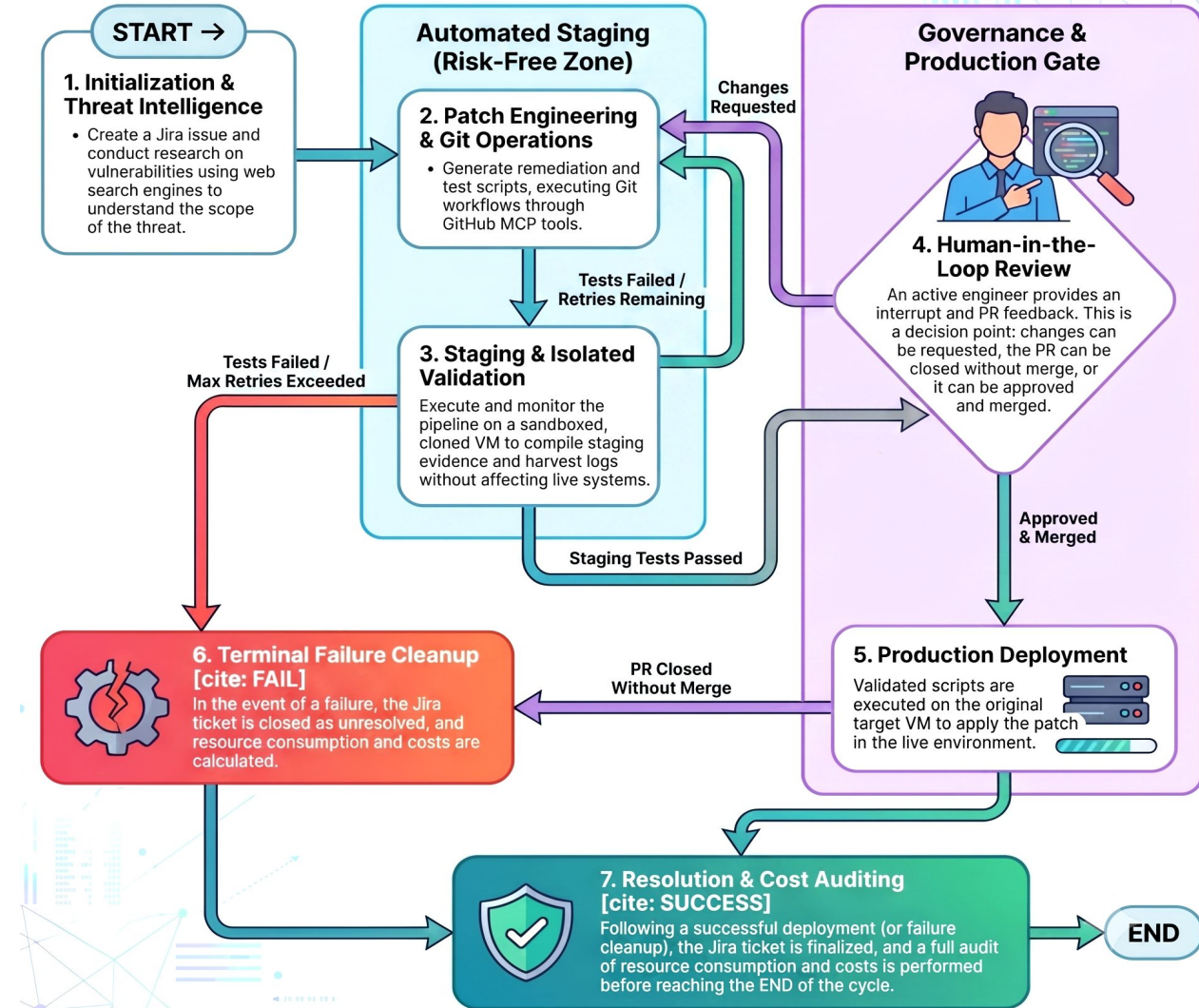
If validation fails, use execution logs from Amazon S3 to improve the scripts and retry automatically.

4. Human Review

Pauses for engineer approval after updating JIRA status. If not approved, the agent uses feedback to improve scripts and retry.

5. Deployment & Closure

After approval, the patch is applied to the target VM. Records final status and updates JIRA as Resolved or Unresolved.



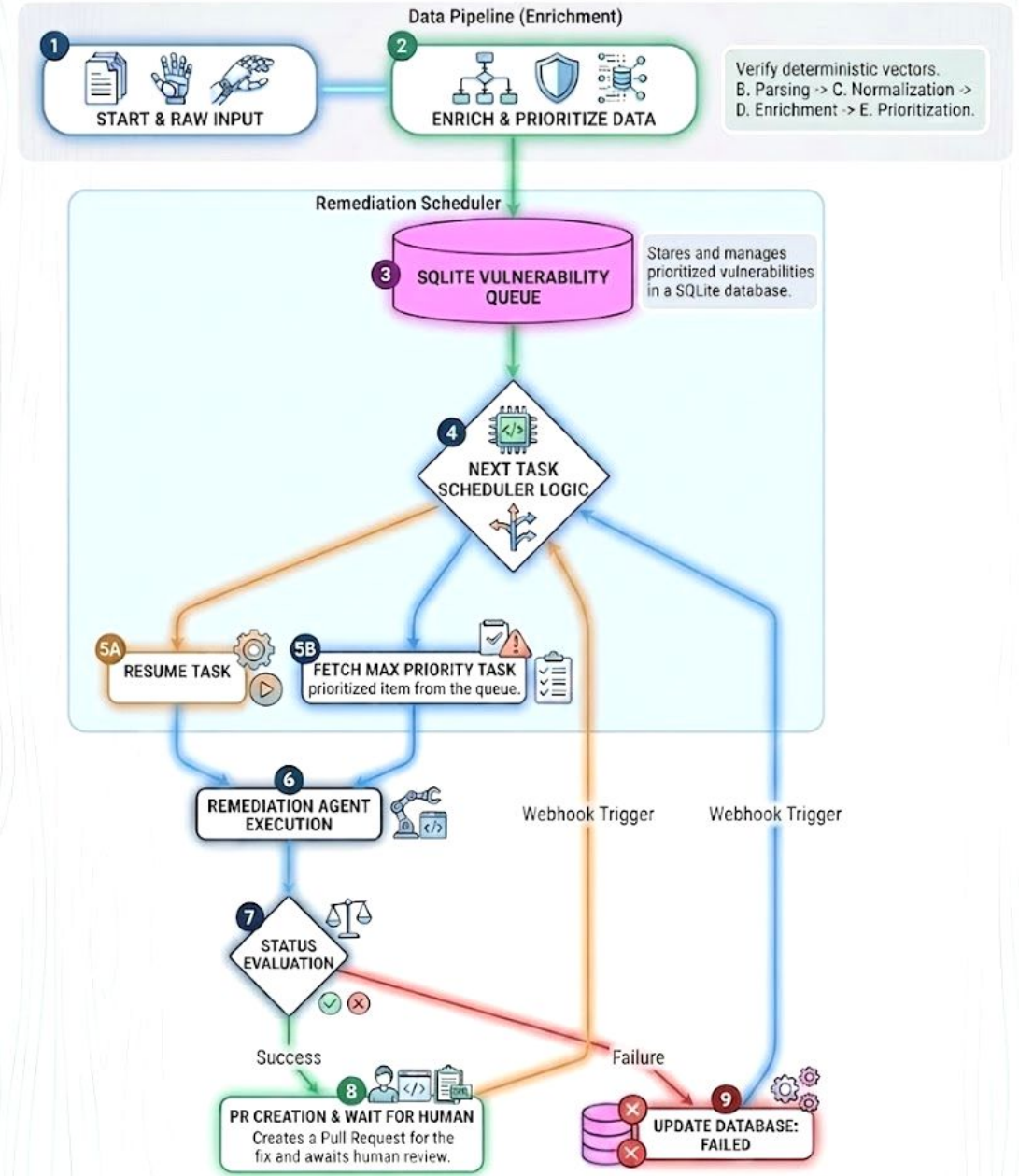
Remediation Priority Scheduler

Continuous Workflow Execution

When a vulnerability enters a waiting state (e.g., human approval), the scheduler immediately processes the next highest-priority vulnerability to ensure uninterrupted execution.

Priority-Based Scheduling

Vulnerabilities are maintained in an SQLite priority queue, where the scheduler always selects the highest-priority pending item for remediation.



Database Schema & Cron Jobs

Automated synchronization of external intelligence sources into local databases.

Scheduled Ingestion

Scheduled ingestion of NVD, EPSS, KEV, and exploit intelligence sources.

Incremental Sync

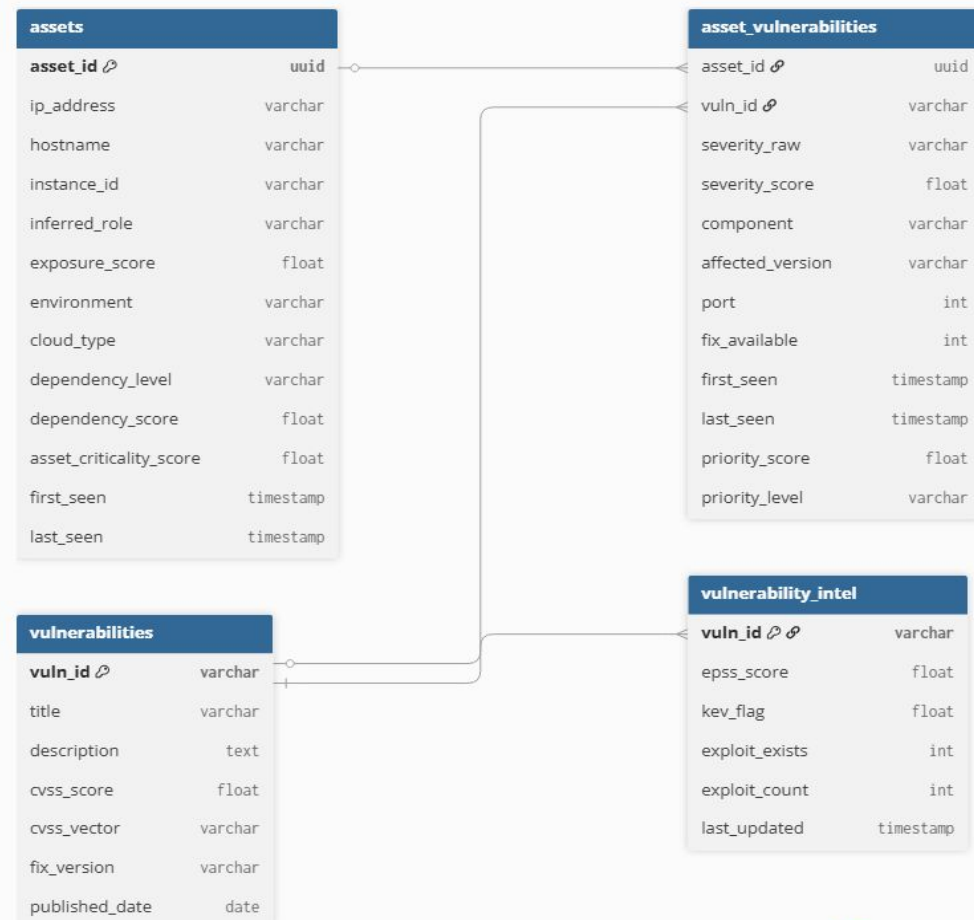
Performs incremental updates and batch upserts.

Local Intelligence Repository

Maintains near-real-time local threat intelligence repositories.

Negligible Runtime Dependency

Eliminates runtime API dependencies during vulnerability enrichment.



Tech Stack



Next.js

Build user dashboard and monitoring interface with fast UI.



LangChain

Integrates Large Language Models (LLMs) with tools for reasoning.



LangGraph

Manages graph-based agentic workflows and execution state.



FastAPI

Backend API framework for connecting system components.



Python

Primary language for analysis, automation, and AI workflows.



WebSocket

Enables real-time communication for live status updates.



PostgreSQL

Secure, scalable relational database for records and assets.



SQLite

Lightweight database for fast local workflow state storage.



Key Learnings & Takeaways



End-to-End Vuln Management

Practical cybersecurity expertise automating the full lifecycle — from risk assessment & prioritization to remediation & validation.



Event-Driven HITL Workflow

Built state-checkpointed, webhook-triggered agent resumption for scalable Human-in-the-Loop automated remediation.



Risk-Based Prioritization

Fused CVSS, EPSS, KEV, asset criticality & AI enrichment into a unified scoring model to drive smarter remediation order.



Self-Healing AI Agents

Agents that auto-detect failures, recover workflows, and ensure continuous execution with minimal manual intervention.



Full-Stack AI Ecosystem Integration

Hands-on with AWS, Jira, MCP, LangGraph, FastAPI, PostgreSQL, SQLite & LangChain - building enterprise-grade AI SecOps Pipeline.



Errors / Challenges Faced



Sequential Remediation Bottleneck

Single-queue execution stalled throughput — each workflow awaited human approval before the next could start.



Truncated CI Pipeline Error Logs

API-fetched CI logs were cut off, giving the LLM incomplete error context for diagnosis.



LLM Tool-Call Loop & Cost Spikes

LLM entered 3-min tool-calling loops, spiking Tavily API costs — required intensive engineering to fix.



Conclusion: Zero-Touch Vulnerability Remediation



Platform Transformation

Converts a manual, non-scalable process into a low-latency, zero-touch remediation pipeline — human involvement reserved for HITL validation only.



Enterprise Scalability

Handles ~5,000 vulnerability findings per week via decoupled, concurrent processing — throughput scales linearly achieving near 0-system idle time.



Under-3-Minute MTTR

Automated enrichment, prioritization, and orchestration reduce mean time to remediation to under 2 minutes per vulnerability workflow.



Local Threat Intelligence

Cron-maintained local replicas of NVD, EPSS, KEV, and ExploitDB enable enrichment lookups with minimal external API dependency.



Full Lifecycle Traceability

Jira integration tracks every vulnerability through Open → Human In The Loop → Unresolved → Resolved with complete audit history.



Future Scope



Non-CVE Vulnerability Support

Extend the platform to identify, store, enrich, and prioritize non-CVE security findings beyond traditional vulnerability databases.



Cross-Identifier Asset Mapping

Unify assets discovered via different identifiers—IP, hostname, instance ID—across multiple scanners into a single coherent view.



Approved Remediation Repository

Maintain an Asset + Vulnerability Approved Script mapping to enable fully autonomous, repeatable future remediations.



Multi-Agent Concurrent Remediation

Introduce parallelized remediation agents to improve throughput, reduce execution time, and scale remediation at enterprise speed.



References

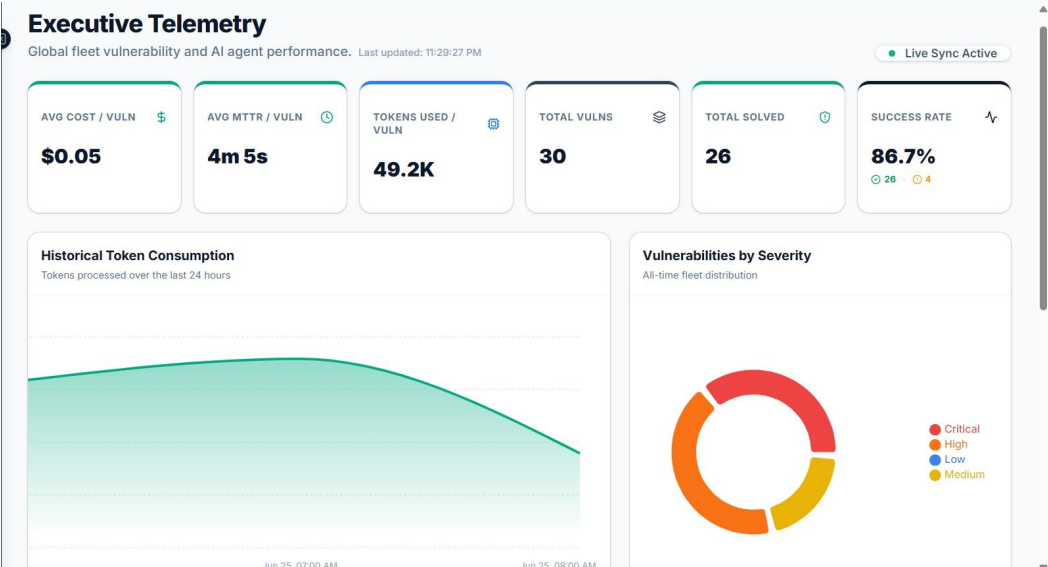
- 01 Product Documentation**
<https://docs.google.com/document/d/1PnZx-qF4nwbL9DalzkBZWzoOjERTiRK0OMiNRyG5Y30/edit?tab=t.0>
- 02 Rapid7 Risk Strategies:** <https://docs.rapid7.com/nexpose/working-with-risk-strategies-to-analyze-threats/>
- 03 CISA KEV Catalog:** <https://www.cisa.gov/known-exploited-vulnerabilities-catalog>
- 04 FIRST EPSS Model:** <https://www.first.org/epss/model>
- 05 Qualys Asset Management Slides:**
<https://cdn2.qualys.com/docs/mktg/2021/qsc/training/virtual/day-2-cybersecurity-asset-management/csam-qsc2021-slides.pdf>
- 06 CISA SSVC:** <https://www.cisa.gov/stakeholder-specific-vulnerability-categorization-ssvc>



Demo

▶ Watch Video Demo: youtu.be/bE-3SrpEB_A

Executive Telemetry Dashboard



Remediation Command Center

